

이스트소프트 인프라 보안 부트캠프 10기
3차(최종) 팀 프로젝트

기업 정보보호 점검 결과보고서

FM 8+ 통신사 인프라 종합 보안 진단

Red Team 모의해킹 · Blue Team 보안 관제 통합 검증

대상 시스템	FM 8+ (http://fm8plus.com)
점검 기간	2026.07.27 ~ 2026.08.03
수행 팀	팔로팔로미 (8팀)
작성자	김혜미

목차

1. 점검 개요	3
1.1 점검 배경 및 목적	3
1.2 점검 대상	3
1.3 점검 범위 및 수행 체계	3
1.4 점검 방법론 및 원칙	4
2. 종합 점검 결과 요약	5
2.1 핵심 지표 요약	5
3. 모의해킹(Red Team) 진단 결과	6
3.1 발견 취약점 종합	6
3.2 취약점 결합 공격 시나리오	6
3.3 근본 원인 종합 분석	6
4. 보안 관제(Blue Team) 동작 검증 결과	8
4.1 관제 체계 구성	8
4.2 IDS/IPS·WAF 탐지·차단 룰 구축 현황	9
4.3 IDS/IPS·WAF 탐지·차단 결과 및 Alert 로그 검증	17
4.4 SIEM 기반 공격 유형별 탐지 검증	21
4.5 정상 vs 악성 트래픽 식별 검증	22
4.6 관제 유효성 종합 평가	22
5. 취약점-관제 상관 분석	23
5.1 탐지 커버리지 매트릭스	23
5.2 탐지 사각지대 분석	24
6. 개선 필요사항	25
6.1 애플리케이션 보안 개선	25
6.2 보안 관제·탐지 체계 개선	25
6.3 프로세스·아키텍처 개선	25
7. 종합 결론 및 대응 우선순위	25
7.1 종합 보안 성숙도 평가	25
7.2 대응 우선순위 로드맵	26

1. 점검 개요

1.1 점검 배경 및 목적

본 점검은 통신사 가상 기업 인프라 'FM 8+'를 대상으로, 실제 침해사고 대응 체계를 축소 재현하여 조직의 정보보호 수준을 종합 진단하는 것을 목적으로 합니다. 2025년 발생한 통신사 인증 인프라(HSS) 침해 사고를 모티브로, 웹 애플리케이션 취약점이 실제 서버 장악과 개인정보 유출로 어떻게 연결되는지를 실증하고, 이를 탐지·차단·분석하는 보안 관제 체계가 유효하게 동작하는지를 함께 검증하였습니다.

특히 본 보고서는 개별 취약점 진단(모의해킹 결과보고서)이나 개별 탐지 검증(로그 통합분석 자료)을 넘어, 'Red Team 공격 → 로그 수집 → Blue Team 탐지·분석 → 대응'으로 이어지는 하나의 보안 진단 파이프라인이 실제로 연결되어 동작하는지를 상위 관점에서 종합 평가하는 데 목적이 있습니다.

1.2 점검 대상

항목	내용
대상 서비스	FM 8+ (통신사 테마 웹 애플리케이션)
접속 주소	http://fm8plus.com (팀 격리 사설망 내부)
서버 환경	Ubuntu Linux, Apache 2.4.58, PHP, MariaDB
관제 환경	pfSense(방화벽) → IDS/IPS → WAF → SIEM(ELK Stack: Filebeat·Logstash·Elasticsearch·Kibana)
점검 위치	Kali Linux (VirtualBox 격리 가상환경, 스냅샷 확보)

1.3 점검 범위 및 수행 체계

본 점검은 OWASP Top 10 기반 웹 애플리케이션 취약점 진단과, 해당 공격 트래픽에 대한 관제 체계 탐지 검증을 범위로 합니다. 팀 단위로 공격·방어·탐지·분석 역할을 분담하여 하나의 파이프라인을 구성하였습니다.

구분	담당	역할
인프라	조경익	가상 기업 인프라 및 취약 서비스 구축
Red Team	김혜미	모의해킹 수행 및 취약점 진단
탐지·차단	이찬근	IDS/IPS·WAF 탐지 룰 및 자동화
로그분석	정슬기	SIEM 통합 로그 수집·상관분석
보안장비	김유선	방화벽·IDS/IPS·WAF 배치 및 설정

1.4 점검 방법론 및 원칙

- 모든 테스트는 팀이 자체 구축한 격리 가상환경(VirtualBox Internal Network) 내에서만 수행하였으며, 실제 서비스 시스템은 대상으로 하지 않았습니다.
- 공격 재현 전 대상 VM 스냅샷을 확보하여 원복 가능한 상태를 유지하였습니다.
- 각 취약점은 재현 → 증적 확보 → 근본 원인 분석 → 대응방안 순으로 진단하였고, 동일 공격 트래픽을 관제 대시보드에서 교차 검증하였습니다.
- 공격자 관점(악용 가능성)과 방어자 관점(탐지·차단·대응)을 균형 있게 기술하였습니다.

점검 수행 도구 및 버전

점검 결과의 재현성을 확보하기 위해, 진단·탐지·분석 각 단계에서 사용한 도구와 버전을 다음과 같이 명시합니다.

구분	도구	용도
정보수집	Nmap	포트·서비스 스캔(정찰 단계 트래픽 생성)
취약점 진단	Nikto	웹 서버 설정·알려진 취약 경로 스캔
취약점 진단	Burp Suite	요청 가로채기·파라미터 조작(IDOR, Session Fixation)
취약점 진단	sqlmap	SQL Injection 자동 탐지 및 DB 덤프
탐지·차단	Suricata	IDS/IPS 커스텀 룰 적용 및 인라인 차단
탐지·차단	ModSecurity+ OWASP CRS	WAF 애플리케이션 계층 필터링
로그분석	ELK Stack	Filebeat 수집 → Elasticsearch 저장 → Kibana 시각화
실습환경	VirtualBox / Kali Linux	격리 가상환경(Internal Network) 및 스냅샷 관리

2. 종합 점검 결과 요약

본 점검 결과, FM 8+ 웹 애플리케이션에서 OWASP Top 10 기반 5개 취약점이 모두 실제 익스플로잇 가능한 상태로 실증되었으며, 이 중 3건(SQL Injection, Stored XSS, Unrestricted File Upload)은 서버 장악(RCE) 또는 전체 회원정보 유출로 직결되는 치명(Critical) 등급으로 확인되었습니다. 동시에 방어 측면에서는 진단 결과를 반영한 커스텀 탐지·차단 룰 18종(IDS/IPS 15 · WAF 3)을 pfSense Suricata와 ModSecurity에 적용하여 전 룰이 정상 트리거되고 그중 16종이 실제 차단(IPS drop 13 · WAF 403 거부 3)으로 동작함을 확인하였으며, SIEM 통합 관제 대시보드를 통해 정찰(포트 스캔) 단계부터 웹 애플리케이션 공격(SQLi/XSS)까지의 악성 트래픽이 정상 트래픽과 분리되어 실시간 탐지됨을 검증하였습니다.

다만 차단은 사전에 등록된 고정 시그니처에 한정되어 인코딩 변형·명령어 치환 등의 우회에 취약하고, 탐지 결과가 담당자에게 전달되는 자동 경보(Alert) 체계와 공격자 IP 동적 차단(SOAR) 연동은 미구축 상태입니다. 또한 IDOR와 같이 정상 요청과 형태가 유사한 공격은 차단 시 정상 기능이 함께 막히는 문제로 alert 전용 운영에 머물러, 여전히 탐지 사각지대로 남아 있음을 확인하였습니다. 따라서 애플리케이션 시큐어 코딩 조치와 관제 체계 자동화(경보·상관분석·차단 연동)를 병행하는 것이 핵심 개선 방향입니다.

2.1 핵심 지표 요약

점검 지표	결과
발견 취약점	총 5건 (Critical 3건 · High 2건)
공격 실증 성공률	5 / 5 (100%) — 진단 대상 전 항목 익스플로잇 성공
탐지·차단 룰 구축	커스텀 룰 18종 (IPS drop 13 · alert 2 / WAF deny 3) — 전 룰 트리거 확인
관제 탐지 커버리지	확실 탐지 2건 · 제한적 탐지 2건 · 사각지대 1건
주요 미비점	자동 경보(Alert) 미구축, 동적 IP 차단(SOAR) 미연동, IDOR 탐지 사각지대, 시그니처 우회 가능성

3. 모의해킹(Red Team) 진단 결과

3.1 발견 취약점 종합

진단 대상 5개 항목 모두에서 취약점이 실증되었습니다. 취약점별 심각도, 실증 결과, 핵심 근본원인은 다음과 같습니다.

심각도는 실증된 피해 범위를 기준으로 산정하였습니다. 원격 코드 실행(RCE)이나 전체 회원 DB 탈취로 직결되는 항목은 치명(Critical), 인증된 사용자 권한 범위를 벗어난 정보 노출이나 세션 탈취로 이어지는 항목은 높음(High)으로 분류하였습니다.

※ 취약점별 상세 재현 절차, 요청·응답 전문, 화면 증적 및 개별 대응 코드는 별도 산출물인 「모의해킹 결과보고서」에 수록되어 있으며, 본 장은 종합 진단 관점의 요약에 해당합니다.

No	취약점	OWASP	심각도	실증 결과	핵심 근본원인
1	SQL Injection	A05	Critical	회원 DB 전체 덤프 및 admin 계정 로그인 성공	입력값 미검증 쿼리 결합 (Prepared Statement 미적용)
2	Session Fixation	A07	High	로그인 전/후 세션ID 미변경 확인	로그인 성공 시 세션 재발급(session_regenerate_id) 누락
3	Stored XSS	A05	Critical	스크립트 실행 및 세션 쿠키 탈취	출력 시 HTML 인코딩 미적용
4	IDOR	A01	High	파라미터 조작으로 타 회원 개인정보 열람	리소스 소유자 검증(인가) 로직 부재
5	Unrestricted File Upload	A02	Critical	웹shell 업로드 및 원격 명령 실행(RCE) 성공	확장자/파일 유형 서버측 검증 부재

3.2 취약점 결합 공격 시나리오

개별 취약점은 단독으로도 위험하지만, Stored XSS와 Session Fixation이 결합될 경우 인증 절차 없이 관리자 세션을 완전히 탈취할 수 있음을 실증하였습니다. 이는 개별 항목 점검을 넘어 취약점 간 연계 가능성을 함께 평가해야 하는 이유를 보여줍니다.

- ① [Stored XSS] 1:1 문의 게시판에 세션 쿠키를 외부로 전송하는 스크립트를 등록합니다.
- ② [연계] 관리자가 해당 문의글을 열람하는 순간 스크립트가 실행되어 관리자의 PHPSESSID가 공격자에게 전송됩니다.
- ③ [Session Fixation] 서버가 세션을 재발급하지 않으므로, 탈취된 PHPSESSID는 열람 이후에도 유효한 관리자 세션으로 계속 사용 가능합니다.

- ④ [결과] 공격자는 탈취한 PHPSESSID 를 그대로 재사용(curl -b)하여 로그인 절차 없이 관리자 권한으로 시스템에 접근합니다.

→ 세션 쿠키에 HttpOnly 속성 하나만 적용되어 있었다라도 ①단계의 document.cookie 접근이 차단되어 전체 공격 체인이 성립하지 않았을 것입니다. 개별 대응책 하나가 갖는 파급력을 보여주는 사례입니다.

3.3 근본 원인 종합 분석

발견된 5개 취약점은 표면적 증상은 다르지만, 근본 원인은 소수의 공통된 개발 관행으로 수렴합니다.

- 입력값 신뢰 — 사용자 입력을 검증·분리 없이 SQL 쿼리(SQLi)나 파일 저장 경로(File Upload)에 그대로 사용합니다.
- 출력/저장 단계 신뢰 과잉 — 저장·출력 시 이스케이프(XSS)나 세션 재발급(Session Fixation) 같은 안전 조치를 누락합니다.
- 인증과 인가의 혼동 — 로그인 여부(인증)만 확인하고, 해당 리소스에 접근할 권한(인가)은 검증하지 않습니다(IDOR).
- 평문 비밀번호 저장 — 인증에 bcrypt 해시가 아닌 평문 컬럼(password_plain)을 사용하여, DB 유출 시 피해가 즉시 확대됩니다.

즉 다수의 취약점이 ‘입력값 검증 부재’와 ‘출력/저장 단계의 신뢰 과잉’이라는 공통 근본 원인을 공유하고 있어, 개발 단계에서의 시큐어 코딩 가이드라인 부재가 구조적 원인으로 판단됩니다.

4. 보안 관제(Blue Team) 동작 검증 결과

4.1 관제 체계 구성

공격 트래픽은 방화벽(pfSense) → IDS/IPS → WAF → 웹서버 경로로 유입되며, 각 계층의 로그와 웹서버 Access Log가 Filebeat를 통해 수집되어 SIEM(ELK Stack)의 통합 관제 대시보드로 집계됩니다. 관제 검증은 이 대시보드에서 공격 유형별로 이상 징후가 실시간 식별되는지를 기준으로 수행하였습니다.

구성 요소	역할
pfSense	네트워크 방화벽 / 게이트웨이 트래픽 관문
IDS/IPS · WAF	Suricata · ModSecurity 기반 침입 탐지 및 웹 공격 필터링
Filebeat	웹서버 Access Log 등 로그 수집 에이전트
ELK Stack	Logstash 정제 → Elasticsearch 저장 → Kibana 시각화/통합 관제

점검 환경 IP 할당 및 검증 시점

관제 파이프라인은 점검 기간 중 두 차례에 걸쳐 단계적으로 구성되었으며, pfSense 세그먼트 재배치에 따라 검증 시점별로 사용된 IP 대역이 다릅니다. 이후 4.3~4.5의 증적 화면을 해석할 때 기준이 되는 정보이므로 다음과 같이 명시합니다.

구간	구성 요소	최종 구성
공격자	Kali Linux	172.30.1.6
경계	pfSense WAN	172.30.1.100 (WAN VIP)
경계	pfSense LAN	192.168.10.1
DMZ	WAF(ModSecurity)	192.168.10.11
DMZ	웹서버 (FM 8+)	192.168.10.12
내부	직원 PC	192.168.30.11
내부	DB 백업 서버	192.168.50.11

4.2 IDS/IPS·WAF 탐지·차단 룰 구축 현황

ET Open Rules와 같은 범용 오픈소스 룰셋은 일반화된 공격 패턴만을 다루기 때문에, FM 8+ 서비스 고유의 취약 지점(로그인 처리 경로, 문의 게시판, member_id 파라미터, 업로드 디렉터리)에서 발생하는 공격은 탐지되지 않거나 근거가 모호한 경보로만 남습니다. 이에 3장의 모의해킹 진단 결과를 입력값으로 삼아, 실제로 익스플로이트에 사용된 요청 형태를 기준으로 커스텀 Suricata 룰 15종을 작성해 pfSense의 Suricata 인터페이스(WAN/LAN)에 적용하고, 이와 별도로 애플리케이션 계층에는 ModSecurity 커스텀 룰 3종을 추가하여 총 18종의 탐지·차단 룰을 구축하였습니다.

룰은 처음부터 차단으로 적용하지 않고, 전 룰을 alert(탐지 전용)로 먼저 운영하여 정상 트래픽에서의 오탐 발생 여부를 관찰한 뒤, 정상 업무 요청과 명확히 구분되는 13종만 drop(인라인 차단)으로 승격하는 단계적 적용 절차를 따랐습니다. 이는 차단 정책이 곧바로 서비스 가용성 침해로 이어질 수 있는 IPS 운영의 기본 원칙에 해당합니다.

구분	적용 지점	룰 수	drop(차단)	alert(탐지)
WAN	Suricata → WAN 인터페이스 (외부 → 웹서비스)	10종	8종	2종
LAN	Suricata → LAN 인터페이스 (내부 구간 이동)	5종	5종	—
WAF	ModSecurity → fm8plus_custom.conf (애플리케이션 계층)	3종	3종 (deny 403)	—
합계	WAN + LAN + WAF	18종	16종	2종

※ 룰 문법·동작은 로컬 검증 VM(Ubuntu + DVWA + ModSecurity + Suricata)에서 1차 검증한 뒤, IDS/IPS 룰은 pfSense의 custom.rules에, WAF 룰은 웹서버의 fm8plus_custom.conf에 최종 반영하였습니다.

WAN 룰 — 외부 공격자 → FM 8+ 웹서비스

#	SID	탐지 대상	대응 Red Team 진단 항목	Action
1	1000001	SQL Injection (UNION SELECT)	3.1 No.1 SQL Injection (Critical)	drop
2	1000002	Stored XSS (<script)	3.1 No.3 Stored XSS (Critical)	drop
3	1000003	로그인 반복 시도 (Brute Force)	인증 무차별 대입 — 계정 탈취 선행 단계	drop
4	1000004	PHP 웹셸 업로드	3.1 No.5 Unrestricted File Upload (Critical)	drop
5	1000005	관리자 문의페이지 접근	Stored XSS 실행 트리거 지점 모니터링	alert
6	1000006	IDOR (member_id 파라미터)	3.1 No.4 IDOR (High)	alert
7	1000007	Directory Traversal (../)	경로 조작을 통한 시스템 파일 접근	drop
8	1000008	sqlmap 스캐너 탐지	자동화 취약점 스캐닝(정찰 단계)	drop
9	1000009	민감 파일 접근 (.env)	DB 접속정보·시크릿 노출 시도	drop

#	SID	탐지 대상	대응 Red Team 진단 항목	Action
10	1000010	Command Injection (whoami)	웹쉘 업로드 이후 원격 명령 실행(RCE)	drop

LAN 룰 — 침해 이후 내부 확산 및 외부 통신

#	SID	탐지 대상	가정한 침해 시나리오 (출발지 → 목적지)	Action
1	1000101	리버스셸 아웃바운드 (4444)	장악된 웹서버(192.168.10.12) → 공격자 PC(172.30.1.6) 셸 연결	drop
2	1000102	BPFDoor 매직 트리거 (31337)	공격자(직원PC 대체 시연) → 웹서버에 상주한 백도어 활성화	drop
3	1000103	내부 포트 스캔	장악된 웹서버 → DB 백업서버(192.168.50.11) 내부 정찰	drop
4	1000104	SSH 브루트포스 (22)	직원PC(192.168.30.11) → 웹서버 SSH 계정 무차별 대입	drop
5	1000105	비인가 원격제어·터널링 (5938, 7070)	직원PC의 비인가 원격툴 → 외부 중계 PC 접속(C2 우회 경로)	drop

※ LAN 룰은 "웹 취약점으로 서버가 이미 장악된 이후"를 전제로 설계되었습니다. 즉 WAN 룰이 침입 차단(Prevention), LAN 룰이 확산 차단(Containment)을 담당하는 이중 방어 구조입니다.

WAN 적용 룰 전문 (10종) — 외부 공격자 → FM 8+ 웹서비스

[1000001] FM8+ SQL Injection UNION SELECT DROP

```
drop http any any -> any any (msg:"FM8+ SQL Injection UNION SELECT";
  flow:to_server,established; http.request_body; content:"UNION SELECT";
  nocase; classtype:web-application-attack; sid:1000001; rev:1;)
```

- **탐지 조건** — 클라이언트→서버 방향의 확립된 HTTP 세션에서, 요청 본문에 "UNION SELECT" 문자열이 대소문자 무관하게 포함된 경우 매칭됩니다.
- **대응 효과** — 3.1 No.1에서 회원 DB 전체를 덤프하는 데 사용한 UNION 기반 컬럼 추출 쿼리가 웹서버에 도달하기 전에 폐기됩니다. classtype이 web-application-attack이므로 Priority 1로 분류되어 관제 화면 상단에 노출됩니다.

[1000002] FM8+ XSS Script Injection DROP

```
drop http any any -> any any (msg:"FM8+ XSS Script Injection";
  flow:to_server,established; http.request_body; content:"<script";
  nocase; classtype:web-application-attack; sid:1000002; rev:1;)
```

- **탐지 조건** — 게시글 등록과 같은 POST 요청 본문에 "<script" 문자열이 포함된 경우 매칭됩니다. 닫는 괄호까지 매칭하지 않는 이유는 <script src=...>, <script type=...> 등 속성이 붙은 변형까지 포괄하기 위함입니다.
- **대응 효과** — 1:1 문의 게시판에 Stored XSS 페이로드가 DB에 저장되기 전에 차단합니다. 즉 3.2 관리자 세션 탈취 체인의 ①단계 자체가 성립하지 않으므로, 이후 ②~④단계가 연쇄적으로 무력화됩니다.

[1000003] FM8+ Repeated Login POST Requests **DROP**

```
drop http any any -> any any (msg:"FM8+ Repeated Login POST Requests";  
  flow:to_server,established; http.method; content:"POST"; http.uri;  
  content:"login-handler.php"; nocase;  
  threshold:type both,track by_src,count 10,seconds 60; sid:1000003; rev:1;)
```

- **탐지 조건** — POST 메서드이면서 URI가 login-handler.php인 요청이, 동일 출발지 IP 기준으로 60초 안에 10회를 초과하면 매칭됩니다.
- **대응 효과** — 로그인 요청 자체는 정상 트래픽이므로 문자열이 아닌 빈도로 판단합니다. 임계치를 넘긴 시점부터 차단되어 계정 무차별 대입이 저지되며, type both를 사용해 임계치 도달 시 1회만 경보를 남겨 로그 폭주를 방지합니다.

[1000004] FM8+ Suspicious PHP File Upload **DROP**

```
drop http any any -> any any (msg:"FM8+ Suspicious PHP File Upload";  
  flow:to_server,established; http.request_body; content:".php";  
  nocase; classtype:web-application-attack; sid:1000004; rev:1;)
```

- **탐지 조건** — multipart/form-data 업로드 요청의 본문에 포함되는 filename="shell.php" 형태를 겨냥해, 요청 본문 내 ".php" 문자열을 매칭합니다.
- **대응 효과** — 3.1 No.5에서 RCE로 이어진 웹셸 파일이 업로드 디렉터리에 저장되기 전에 차단합니다. 다만 검사 범위가 본문 전체이므로 정상 게시글에 ".php"가 언급되어도 매칭되는 오탐 가능성이 있습니다(4.3 한계 표 참조).

[1000005] FM8+ Admin Inquiry Page Access **ALERT**

```
alert http any any -> any any (msg:"FM8+ Admin Inquiry Page Access";  
  flow:to_server,established; http.uri; content:"/admin_inquiry.php";  
  nocase; sid:1000005; rev:1;)
```

- **탐지 조건** — 관리자 문의 확인 페이지 URI에 대한 모든 접근을 기록합니다. 공격 시그니처가 아니라 위치 기반 관측 룰입니다.
- **대응 효과** — 차단하지 않습니다. 이 페이지는 Stored XSS 페이로드가 실제로 실행되는 지점이므로, XSS 등록 경보(1000002)와 이 접근 시각을 SIEM에서 대조하면 "언제 관리자 세션이 탈취되었는가"를 역추적할 수 있습니다. 차단할 경우 관리자 정상 업무가 마비됩니다.

[1000006] FM8+ Member ID Parameter Access **ALERT**

```
alert http any any -> any any (msg:"FM8+ Member ID Parameter Access";  
  flow:to_server,established; http.uri; content:"member_id=";  
  nocase; sid:1000006; rev:1;)
```

- **탐지 조건** — URI에 member_id 파라미터가 포함된 모든 요청을 기록합니다.
- **대응 효과** — 차단하지 않습니다. IDOR 공격 요청과 회원의 정상 마이페이지 조회는 파라미터 값만 다를 뿐 형태가 완전히 동일하기 때문입니다. 이 룰의 목적은 차단이 아니라, "동일 세션이 짧은 시간에 서로 다른 member_id를 연속 조회"하는 행위 패턴을 SIEM에서 상관분석할 수 있도록 원천 로그를 남기는 데 있습니다.

[1000007] FM8+ Directory Traversal Attempt **DROP**

```
drop http any any -> any any (msg:"FM8+ Directory Traversal Attempt";  
  flow:to_server,established; http.uri.raw; content:"../";  
  sid:1000007; rev:1;)
```

- **탐지 조건** — 정규화 이전의 원본 URI(http.uri.raw)에 상위 디렉터리 이동 문자열 "../"가 포함된 경우 매칭됩니다.
- **대응 효과** — /etc/passwd, 설정 파일 등 웹 문서 루트 바깥 경로에 대한 접근을 차단합니다. raw 버퍼를 사용해 서버 정규화 이전 원문을 검사하지만, 이중 URL 인코딩(%252e%252e%252f)은 문자열이 달라 우회됩니다.

[1000008] FM8+ SQLMap Scanner Detected **DROP**

```
drop http any any -> any any (msg:"FM8+ SQLMap Scanner Detected";  
  flow:to_server,established; http.user_agent; content:"sqlmap";  
  nocase; sid:1000008; rev:1;)
```

- **탐지 조건** — User-Agent 헤더에 "sqlmap" 문자열이 포함된 요청을 매칭합니다.
- **대응 효과** — 자동화 SQLi 스캐너의 기본 UA를 차단해, 수천 건의 페이로드 시도가 시작되기 전 정찰 단계에서 끊습니다. 다만 --user-agent 옵션으로 손쉽게 위조되므로 단독 방어선이 아닌 보조 지표로 취급해야 합니다.

[1000009] FM8+ Sensitive File Access **DROP**

```
drop http any any -> any any (msg:"FM8+ Sensitive File Access";  
  flow:to_server,established; http.uri; content:".env";  
  nocase; sid:1000009; rev:1;)
```

- **탐지 조건** — URI에 ".env" 문자열이 포함된 요청을 매칭합니다.
- **대응 효과** — DB 접속 계정과 시크릿 키가 담긴 환경설정 파일에 대한 직접 요청을 차단합니다. 다만 이는 증상 차단이며, 근본 조치는 해당 파일을 웹 문서 루트 바깥으로 옮기고 웹서버 접근 정책에서 차단하는 것입니다.

[1000010] FM8+ Command Injection Attempt **DROP**

```
drop http any any -> any any (msg:"FM8+ Command Injection Attempt";  
  flow:to_server,established; http.uri.raw; content:"whoami";  
  nocase; sid:1000010; rev:1;)
```

- **탐지 조건** — 원본 URI에 "whoami" 명령어 문자열이 포함된 경우 매칭됩니다.
- **대응 효과** — 업로드된 웹셸에 /uploads/shell.php?cmd=whoami 형태로 명령을 전달하는 RCE 시도를 차단합니다. 1000004(업로드 차단)와 짝을 이루어 "업로드 시점"과 "실행 시점"을 이중으로 감시합니다. 다만 대표 명령어 하나만 매칭하므로 id·uname·cat 등 다른 명령은 미탐입니다.

LAN 적용 룰 전문 (5종) — 침해 이후 내부 확산 및 외부 통신

LAN 룰은 WAN 방화선이 뚫린 이후를 가정합니다. 웹 애플리케이션 취약점으로 서버가 이미 장악되었을 때, 공격자가 지속 통신 채널을 확보하거나 내부 다른 서버로 이동하는 것을 저지하는 것이 목적입니다. 따라서 검사 대상이 HTTP 페이로드가 아니라 TCP 연결의 방향·포트·빈도가 됩니다.

[1000101] FM8+ Reverse Shell Outbound 4444 DROP

```
drop tcp any any -> any 4444 (msg:"FM8+ Reverse Shell Outbound 4444";  
  flow:to_server,established; classtype:trojan-activity;  
  sid:1000101; rev:1;)
```

- **탐지 조건** — 목적지 TCP 4444 포트로 확립된 모든 세션을 매칭합니다. content 조건이 없다는 점이 특징으로, 페이로드가 아니라 연결 자체를 문제로 봅니다.
- **대응 효과** — 3.1 No.5 웹셸로 장악된 서버가 공격자 PC에 거는 아웃바운드 셸 연결을 차단합니다. 방화벽 인바운드 정책만으로는 막을 수 없는 "안에서 밖으로 나가는" 연결을 잡는다는 점에서 의미가 있습니다. 다만 리스너 포트를 443 등으로 바꾸면 즉시 무력화되므로, 장기적으로는 포트가 아닌 비콘 주기·세션 지속시간 기반 탐지가 필요합니다.

[1000102] FM8+ BPFDoor Magic Trigger DROP

```
drop tcp any any -> any 31337 (msg:"FM8+ BPFDoor Magic Trigger";  
  flow:to_server; content:"MAGIC"; classtype:trojan-activity;  
  sid:1000102; rev:1;)
```

- **탐지 조건** — 목적지 TCP 31337로 향하는 서버 방향 패킷에 "MAGIC" 문자열이 포함된 경우 매칭됩니다. 다른 룰과 달리 established를 지정하지 않은 것이 핵심입니다.
- **대응 효과** — 악성코드 분석보고서에서 다른 BPFDoor의 매직패킷 트리거를 차단해, 잠복 중인 백도어가 깨어나는 것을 막습니다. established를 제외한 이유는 BPFDoor가 3-way handshake 없이 단발 패킷만으로 활성화되기 때문으로, established를 넣으면 세션이 성립하지 않아 룰이 아예 매칭되지 않습니다. 실제 침해사고(2025년 통신사 HSS 사고)에서 확인된 동작 특성을 룰 설계에 반영한 사례입니다.

[1000103] FM8+ Internal Port Scan DROP

```
drop tcp any any -> any any (msg:"FM8+ Internal Port Scan";  
  flags:S; flow:to_server;  
  threshold:type both,track by_src,count 20,seconds 5;  
  classtype:attempted-recon; sid:1000103; rev:1;)
```

- **탐지 조건** — SYN 플래그만 세워진 패킷(flags:S)이 동일 출발지 기준 5초 안에 20회를 초과하면 매칭됩니다. SYN 스캔은 연결을 완성하지 않고 SYN만 뿌리는 방식이므로 이 조건으로 식별됩니다.
- **대응 효과** — 장악된 웹서버가 DB 백업서버 등 내부 대역을 훑는 수평 이동(Lateral Movement) 직전의 정찰 행위를 차단합니다. 개별 SYN은 정상 연결 시도와 구분되지 않으므로 반드시 임계치와 함께 사용해야 합니다.

[1000104] LAN - Internal SSH Brute Force Attempt Detected DROP

```
drop tcp any any -> any 22 (msg:"LAN - Internal SSH Brute Force Attempt Detected";  
  flags:S; threshold: type threshold, track by_src, count 5, seconds 60;  
  sid:1000104; rev:1;)
```

- **탐지 조건** — 목적지 22번 포트로 향하는 SYN 패킷이 동일 출발지에서 60초 안에 5회를 초과하면 매칭됩니다.
- **대응 효과** — 내부 계정에 대한 SSH 무차별 대입을 차단합니다. 1000103보다 임계치가 훨씬 낮은데(20회/5초

→ 5회/60초), 대상이 SSH 한 포트로 한정되어 정상 사용 빈도가 낮기 때문입니다. type threshold를 사용해 임계치를 넘길 때마다 반복 경보를 남기므로 공격 지속 시간을 로그로 추적할 수 있습니다.

[1000105] LAN - Unauthorized Remote Control or Tunneling Traffic **DROP**

```
drop tcp any any -> any [5938, 7070] (msg:"LAN - Unauthorized Remote Control  
or Tunneling Traffic"; flow:to_server,established;  
sid:1000105; rev:1;)
```

- **탐지 조건** — 목적지 포트 5938(TeamViewer) 또는 7070으로 확립된 세션을 매칭합니다. 대괄호로 복수 포트를 한 룰에 지정하였습니다.
- **대응 효과** — 직원 PC에 승인 없이 설치된 원격제어 도구가 외부 중계 서버로 만드는 터널을 차단합니다. 이런 도구는 아웃바운드 연결을 스스로 열기 때문에 방화벽 인바운드 정책을 우회하며, 공격자에게는 정상 소프트웨어로 위장된 C2 경로가 됩니다. 방화벽 아웃바운드 정책과 함께 이중으로 막는 것이 바람직합니다.

drop 승격 / alert 유지 판단 근거

- **drop 승격(13 종)** — UNION SELECT, <script, ../, sqlmap User-Agent, whoami, .env 와 같이 정상 업무 트래픽에서는 발생할 여지가 없는 명시적 공격 시그니처입니다. 오탐으로 인한 정상 서비스 차단 위험이 낮아 인라인 차단으로 전환하였습니다.
- **alert 유지(2 종)** — 1000005(관리자 문의페이지 접근)와 1000006(member_id 파라미터)은 공격 요청과 정상 요청이 문자열 수준에서 완전히 동일합니다. 차단할 경우 관리자의 정상 문의 확인과 회원의 정상 마이페이지 조회가 함께 막혀 가용성이 침해되므로 탐지 전용으로 유지하였습니다.

→ 이 판단은 5.2에서 분석한 "IDOR는 시그니처 기반 탐지의 사각지대"라는 결론과 정확히 일치합니다. 문자열 시그니처만으로는 인가 위반을 판별할 수 없으므로, 해당 항목은 차단 룰이 아니라 애플리케이션 계층의 인가 검증 로직으로 해결해야 하는 영역입니다.

WAF(ModSecurity) 적용 룰 전문 (3종) — 애플리케이션 계층 심층 검사

IDS/IPS와 WAF는 같은 공격을 보더라도 검사하는 대상이 다릅니다. Suricata는 네트워크를 지나는 패킷에서 문자열을 찾는 반면, ModSecurity는 웹서버 앞단에서 HTTP 요청을 애플리케이션 수준으로 파싱한 뒤 "어떤 파라미터의 값인지", "업로드된 파일의 실제 내용물이 무엇인지"까지 구분해 검사할 수 있습니다. 따라서 같은 SQL Injection이라도 WAF는 요청 본문 전체가 아니라 파라미터 값(ARGS)만 골라 정규식으로 검사하므로 오탐이 줄고 우회 저항이 높아집니다.

본 환경에서는 OWASP CRS 기본 룰셋(SQLi 942xxx, XSS 941xxx 계열)에 더해, 3장 진단에서 실제로 성공한 익스플로잇 형태에 맞춘 커스텀 룰 3종을 /etc/modsecurity/fm8plus_custom.conf에 추가하였습니다. 3종 모두 deny:status:403으로 설정하여 탐지와 동시에 요청을 거부합니다.

공격 유형	차단되는 원리	실제 사례
SQL Injection	요청 파라미터 값에 작은따옴표, 주석 기호(--, #), OR, UNION 같은 SQL 문법 요소가 나타나면 인젝션 시도로 판단합니다.	admin' -- 입력 시 CRS 942180-942300-942440과 커스텀 룰 2000001에 동시 매칭되어 차단
Stored XSS	요청 값에 <script>, onerror= 같은 HTML/JS 실행 구문이 포함되면 스크립트 삽입 시도로 판단합니다.	<script>alert(1)</script> 입력 시 XSS 탐지 룰에 매칭되어 저장 전 차단
파일 업로드(웹쉘)	파일명이나 확장자가 아니라 업로드된 파일의 내용을 검사하여, PHP 코드가 포함되어 있으면 실행 가능한 스크립트 업로드로 판단합니다.	PHP 코드가 담긴 파일을 .jpg로 위장해도 내용 검사에서 적발되어 차단
IDOR (차단 불가)	요청 자체가 문법적으로 완전히 정상입니다. 파라미터 숫자 하나가 바뀐 것뿐이므로 WAF가 패턴으로 정상·공격을 구분할 방법이 없습니다.	?member_id=5 → ?member_id=6은 정상 요청과 동일해 그대로 통과

※ 앞의 세 항목은 "공격에만 나타나는 문자열"이 존재하므로 패턴으로 차단할 수 있지만, IDOR는 그런 문자열이 아예 없습니다. 이것이 IPS(1000006 alert 유지)와 WAF 양쪽에서 IDOR만 차단되지 않는 공통된 이유입니다.

[2000001] FM8+ Custom SQL Injection Detected DENY 403

```
SecRule ARGS "@rx (?i:('\"s*(-|#))|(\bunion\s+select\b)|(\bor\s+1\s*=\s*1\b))"
    "id:2000001,phase:2,deny,status:403,
    msg:'FM8+ Custom SQL Injection Detected',log"
```

- **탐지 조건** — 모든 요청 파라미터 값(ARGS)을 대상으로, ① 작은따옴표 뒤에 주석 기호(-- 또는 #)가 오는 형태, ② union select, ③ or 1=1 세 패턴 중 하나라도 매칭되면 phase:2(요청 본문 파싱 완료 시점)에서 403으로 거부합니다.
- **대응 효과** — Suricata 1000001이 "UNION SELECT" 고정 문자열만 잡던 것을 정규식으로 확장하여, 3.1 No.1에서 사용한 admin' -- 형태의 인증 우회 페이로드까지 포함했습니다. ws*로 공백 개수 변화를, (?i)로 대소문자 변형을 흡수하므로 4.3에서 지적한 단순 변형 우회에 대한 저항력이 IPS 계층보다 높습니다.

[2000002] FM8+ Custom XSS Detected DENY 403

```
SecRule ARGS "@rx <script"
  "id:2000002,phase:2,deny,status:403,
  msg:'FM8+ Custom XSS Detected',log"
```

- **탐지 조건** — 요청 파라미터 값에 <script 문자열이 포함되면 403으로 거부합니다. 1:1 문의 게시판의 본문 파라미터(ARGS:content)가 주된 대상입니다.
- **대응 효과** — Stored XSS 페이로드가 DB에 저장되기 전 애플리케이션 계층에서 한 번 더 차단합니다. Suricata 1000002와 대상이 동일한 의도적 중복으로, IPS 계층이 우회되더라도 WAF에서 다시 걸리는 다층 방어(Defense in Depth) 구조를 만듭니다.

[2000003] FM8+ Custom Webshell Upload Detected (content-based) DENY 403

```
SecRule FILES_TMP_CONTENT "@rx <\?php"
  "id:2000003,phase:2,deny,status:403,
  msg:'FM8+ Custom Webshell Upload Detected (content-based)',log"
```

- **탐지 조건** — 업로드된 파일이 임시 저장된 시점의 실제 내용물(FILES_TMP_CONTENT)에서 <?php 여는 태그를 탐색합니다. 파일명·확장자·Content-Type이 아니라 파일 안에 무엇이 들어 있는지를 보는 것이 핵심입니다.
- **대응 효과** — 본 WAF 룰셋에서 방어 기여도가 가장 높은 룰입니다. Suricata 1000004는 요청 본문의 ".php" 문자열에 의존하므로 shell.jpg처럼 확장자를 위장하면 우회되지만, 이 룰은 확장자와 무관하게 PHP 코드가 담긴 파일을 적발합니다. 즉 4.3에서 지적한 1000004의 우회 가능성을 WAF 계층에서 보완하는 구조입니다.

→ 정리하면 IDS/IPS는 "패킷에 이 문자열이 있는가", WAF는 "이 파라미터의 값이 무엇이고 이 파일의 내용이 무엇인가"를 봅니다. 두 계층이 같은 공격을 서로 다른 근거로 판단하기 때문에, 한쪽을 우회하는 기법이 다른 쪽에는 통하지 않는 상호 보완이 성립합니다.

4.3 IDS/IPS·WAF 탐지·차단 결과 및 Alert 로그 검증

구축한 룰이 실제로 동작하는지 확인하기 위해, 3장에서 수행한 공격 페이로드를 동일하게 재현하여 pfSense Suricata의 Alerts 화면에 경보가 적재되는지와 drop 룰이 실제로 패킷을 차단하는지를 검증하였습니다. WAN 검증은 외부 공격자 PC(172.30.1.6)에서 WAN 가상 IP(172.30.1.100)로 요청을 발생시키고, 해당 요청이 포트포워딩을 통해 후단 WAF(192.168.10.11)로 전달되는 경로를 대상으로 하였습니다.

WAN 구간 탐지·차단 로그

탐지 시각	SID	탐지 내용 (Description)	Class	출발지	Pri
00:41:18	1000001	FM8+ SQL Injection UNION SELECT	Web Application Attack	172.30.1.6	1
00:41:16	1000002	FM8+ XSS Script Injection	Web Application Attack	172.30.1.6	1
00:41:14	1000003	FM8+ Repeated Login POST Requests	Not Assigned	172.30.1.6	3
00:41:12	1000004	FM8+ Suspicious PHP File Upload	Web Application Attack	172.30.1.6	1
00:41:10	1000005	FM8+ Admin Inquiry Page Access	Not Assigned	172.30.1.6	3
00:41:08	1000006	FM8+ Member ID Parameter Access	Not Assigned	172.30.1.6	3
00:41:04	1000007	FM8+ Directory Traversal Attempt	Not Assigned	172.30.1.6	3
00:41:02	1000008	FM8+ SQLMap Scanner Detected	Not Assigned	172.30.1.6	3
00:41:00	1000009	FM8+ Sensitive File Access	Not Assigned	172.30.1.6	3
00:40:57	1000010	FM8+ Command Injection Attempt	Not Assigned	172.30.1.6	3

공통 조건 — 목적지 172.30.1.100:80(WAN VIP) / 프로토콜 TCP / 탐지 일자 2026.08.03. 출발지 포트는 OS가 연결마다 임의의 배정하는 임시 포트이므로 매 요청마다 값이 달라지는 것이 정상입니다.

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
08/03/2026 00:41:18		1	TCP	Web Application Attack	172.30.1.6 	62861 	172.30.1.100 	80 	1:1000001 	FM8+ SQL Injection UNION SELECT
08/03/2026 00:41:16		1	TCP	Web Application Attack	172.30.1.6 	62860 	172.30.1.100 	80 	1:1000002 	FM8+ XSS Script Injection
08/03/2026 00:41:14		3	TCP	Not Assigned	172.30.1.6 	62858 	172.30.1.100 	80 	1:1000003 	FM8+ Repeated Login POST Requests
08/03/2026 00:41:12		1	TCP	Web Application Attack	172.30.1.6 	62849 	172.30.1.100 	80 	1:1000004 	FM8+ Suspicious PHP File Upload
08/03/2026 00:41:10		3	TCP	Not Assigned	172.30.1.6 	62848 	172.30.1.100 	80 	1:1000005 	FM8+ Admin Inquiry Page Access
08/03/2026 00:41:08		3	TCP	Not Assigned	172.30.1.6 	62847 	172.30.1.100 	80 	1:1000006 	FM8+ Member ID Parameter Access
08/03/2026 00:41:04		3	TCP	Not Assigned	172.30.1.6 	62844 	172.30.1.100 	80 	1:1000007 	FM8+ Directory Traversal Attempt
08/03/2026 00:41:02		3	TCP	Not Assigned	172.30.1.6 	62843 	172.30.1.100 	80 	1:1000008 	FM8+ SQLMap Scanner Detected
08/03/2026 00:41:00		3	TCP	Not Assigned	172.30.1.6 	62842 	172.30.1.100 	80 	1:1000009 	FM8+ Sensitive File Access
08/03/2026 00:40:57		3	TCP	Not Assigned	172.30.1.6 	62841 	172.30.1.100 	80 	1:1000010 	FM8+ Command Injection Attempt

[그림 4-1] pfSense Suricata WAN 인터페이스 Alert 화면 — 커스텀 룰 10종 전체 탐지·차단 확인

LAN 구간 탐지·차단 로그

SID	탐지 내용	출발지	목적지	Class
1000101	리버스셸 아웃바운드 (4444)	웹서버 192.168.10.12	공격자 PC 172.30.1.6	Network Trojan
1000102	BPFDoor 매직 트리거 (31337)	직원PC 192.168.30.11	웹서버 192.168.10.12	Network Trojan
1000103	내부 포트 스캔	웹서버 192.168.10.12	DB백업 192.168.50.11	Attempted Recon
1000104	SSH 브루트포스 (22)	직원PC 192.168.30.11	웹서버 192.168.10.12	Not Assigned
1000105	비인가 원격제어 (5938)	직원PC 192.168.30.11	공격자 PC 172.30.1.6	Not Assigned

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
08/03/2026 11:04:41		1	TCP	A Network Trojan was detected	192.168.10.12	48302	172.30.1.6	4444	1:1000101	FM8+ Reverse Shell Outbound 4444
08/03/2026 11:04:23		1	TCP	A Network Trojan was detected	192.168.30.11	41414	192.168.10.12	31337	1:1000102	FM8+ BPFDoor Magic Trigger
08/03/2026 11:04:23		1	TCP	A Network Trojan was detected	192.168.30.11	41414	192.168.10.12	31337	1:1000102	FM8+ BPFDoor Magic Trigger
08/03/2026 11:02:01		2	TCP	Attempted Information Leak	192.168.10.12	36190	192.168.50.11	21	1:1000103	FM8+ Internal Port Scan
08/03/2026 11:01:55		3	TCP	Not Assigned	192.168.30.11	46468	192.168.10.12	22	1:1000104	LAN - Internal SSH Brute Force Attempt Detected
08/03/2026 11:01:55		3	TCP	Not Assigned	192.168.30.11	46450	192.168.10.12	22	1:1000104	LAN - Internal SSH Brute Force Attempt Detected
08/03/2026 11:01:41		3	TCP	Not Assigned	192.168.30.11	58340	172.30.1.6	5938	1:1000105	LAN - Unauthorized Remote Control or Tunneling Traffic

[그림 4-2] pfSense Suricata LAN 인터페이스 Alert 화면 — 내부 확산·백도어 통신 탐지·차단 확인

WAF(ModSecurity) 구간 탐지·차단 로그

WAF 계층의 동작은 ModSecurity 감사로그를 실시간으로 필터링하며 검증하였습니다. 커스텀 룰에만 msg 접두어로 "Custom"을 부여했기 때문에, 아래 명령으로 CRS 기본 룰과 커스텀 룰의 탐지를 분리해 관찰할 수 있습니다.

```
sudo tail -f -n 0 /var/log/apache2/modsec_audit.log | grep --line-buffered "Custom"
```

SQL Injection · Stored XSS · 웹shell 업로드 3종 공격을 순차 수행한 결과, 3건 모두 403으로 거부되었으며 각 의도한 커스텀 룰 ID에 정확히 매칭되었습니다.

공격 유형	검사 대상 변수	매칭된 패턴	매칭 룰 ID	결과
SQL Injection	ARGS:id	(?:unionWs+select)	id 2000001	403 차단
Stored XSS	ARGS:content	<script	id 2000002	403 차단
웹shell 업로드	FILES:file	<W?php (내용 검사)	id 2000003	403 차단

```

blue@blue:~$ sudo tail -f -n 0 /var/log/apache2/modsec_audit.log | grep --line-b
uffered "Custom"
Message: Access denied with code 403 (phase 2). Pattern match "(?i:union\\s+sele
ct)" at ARGS:id. [file "/etc/modsecurity/fm8plus_custom.conf"] [line "1"] [id "2
000001"] [msg "FM8+ Custom SQL Injection Detected"]
Apache-Error: [file "apache2_util.c"] [line 275] [level 3] [client 192.168.10.1]
ModSecurity: Access denied with code 403 (phase 2). Pattern match "(?i:union\\
\\\\s+select)" at ARGS:id. [file "/etc/modsecurity/fm8plus_custom.conf"] [line
"1"] [id "2000001"] [msg "FM8+ Custom SQL Injection Detected"] [hostname "192.16
8.10.11"] [uri "/" ] [unique_id "am_vl9fTBwzjeBMalmznQAAAEY"]
Message: Access denied with code 403 (phase 2). Pattern match "<script" at ARGS:
content. [file "/etc/modsecurity/fm8plus_custom.conf"] [line "2"] [id "2000002"]
[msg "FM8+ Custom XSS Detected"]
Apache-Error: [file "apache2_util.c"] [line 275] [level 3] [client 192.168.10.1]
ModSecurity: Access denied with code 403 (phase 2). Pattern match "<script" at
ARGS:content. [file "/etc/modsecurity/fm8plus_custom.conf"] [line "2"] [id "2000
002"] [msg "FM8+ Custom XSS Detected"] [hostname "192.168.10.11"] [uri "/inquiry
.php"] [unique_id "am_vCMwqW4ttSaa06merAAAAAY"]
Message: Access denied with code 403 (phase 2). Pattern match "\\\\.php$" at FILES
:file. [file "/etc/modsecurity/fm8plus_custom.conf"] [line "3"] [id "2000003"] [
msg "FM8+ Custom Webshell Upload Detected"]
Apache-Error: [file "apache2_util.c"] [line 275] [level 3] [client 192.168.10.1]
ModSecurity: Access denied with code 403 (phase 2). Pattern match "\\\\.php$
" at FILES:file. [file "/etc/modsecurity/fm8plus_custom.conf"] [line "3"] [id "
2000003"] [msg "FM8+ Custom Webshell Upload Detected"] [hostname "192.168.10.11"
] [uri "/upload.php"] [unique_id "am_vl9fTBwzjeBMalmznQAAAEg"]
tail: /var/log/apache2/modsec_audit.log: file truncated

```

[그림 4-3] ModSecurity 감사로그 실시간 필터링 — 커스텀 룰 3종 전부 403 차단 확인

※ 3.1 No.5 파일 업로드 취약점의 경우, IPS(1000004)는 요청 본문의 확장자 문자열을, WAF(2000003)는 파일의 실제 내용을 검사합니다. 확장자 위장 공격에서 IPS는 통과시키지만 WAF는 차단하므로, 두 계층이 함께 있어야 방어가 완성됨을 이 검증에서 확인하였습니다.

검증 결과 요약

- IPS 15 종(WAN 10·LAN 5)과 WAF 3 종 총 18 개 룰이 모두 정상 트리거되었으며, 룰 미동작이나 SID 누락은 확인되지 않았습니다. 특히 SQLi·XSS·웹셸 업로드는 Priority 1(Web Application Attack)로 분류되어 우선순위 기반 대응이 가능함을 확인하였습니다.
- drop 룰 13 종은 경보 적재와 동시에 패킷이 폐기되어, 공격 요청이 후단 웹서버에 도달하지 못했습니다. 즉 4.6 에서 평가하는 '차단' 단계가 실제로 동작함을 인라인 수준에서 실증하였습니다.
- LAN 룰은 침해 이후 단계를 차단합니다. 리버스셸 아웃바운드(4444)와 BPFDoor 매직패킷(31337)이 차단됨으로써, 웹 취약점으로 서버가 장악되더라도 공격자와의 지속 통신 채널(C2) 확보와 내부 수평 이동이 저지되는 다층 방어가 성립합니다.
- 평문(80) 포트 기준 검증 — HTTPS(443)가 아닌 HTTP(80)로 검증한 것은 Suricata 가 TLS 로 암호화된 페이로드 내용을 검사할 수 없기 때문입니다. 룰 동작 자체를 검증하기 위한 의도적 구성이며, 이 제약은 아래 한계 항목에서 개선 과제로 다룹니다.

탐지·차단 체계의 한계 및 우회 가능성

본 룰셋은 대부분 고정 문자열(content) 매칭에 기반하므로, 공격자 관점에서는 다음과 같은 우회가 가능합니다. 실제 운영 환경 적용 시 반드시 보완되어야 하는 항목입니다.

SID	현재 탐지 방식	우회 가능성 (공격자 관점)	보완 방향
1000001	UNION SELECT 문자열 매칭	주석·개행 삽입(UNION/**/SELECT), 대소 문자 혼용, URL 인코딩	PCRE 정규식 + 정규화 후 검사
1000002	<script 문자열 매칭	이벤트 핸들러(onerror=), 태그 등 script 태그 미사용 XSS	태그·핸들러 패턴 확장
1000004	요청 본문 내 ".php" 매칭	.phtml.php5 확장자, 게시글 본문의 정상 ".php" 문자열(오탐)	매직바이트·Content-Type 병행 검사
1000007	URI raw의 "../" 매칭	이중 URL 인코딩(%252e%252e%252f)으로 문자열 회피	URI 정규화(normalize) 후 검사
1000010	whoami 문자열 매칭	명령어 치환(w'h'oami, \${IFS}), Base64 인코딩 실행	명령 실행 결과·프로세스 행위 탐지
1000101	목적지 포트 4444 고정	리스너 포트를 443 등으로 변경하면 즉시 무력화	주기적 비콘·장기 세션 행위 탐지

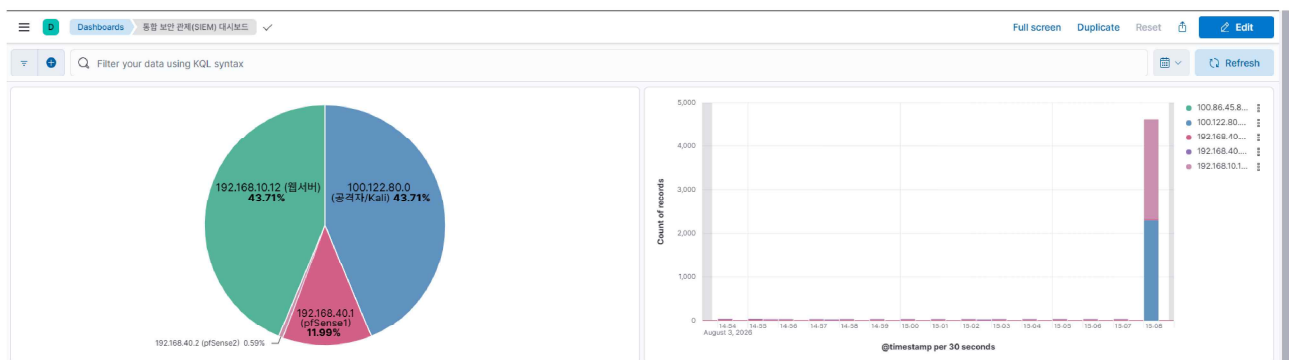
→ 시그니처 기반 탐지는 "알려진 표현"만 잡아냅니다. 따라서 룰셋 고도화(정규식·정규화)와 함께, 페이로드가 아닌 행위(연결 지속시간, 요청 빈도, 세션별 파라미터 변화)를 보는 상관분석 탐지가 병행되어야 방어 공백이 메워집니다.

4.4 SIEM 기반 공격 유형별 탐지 검증

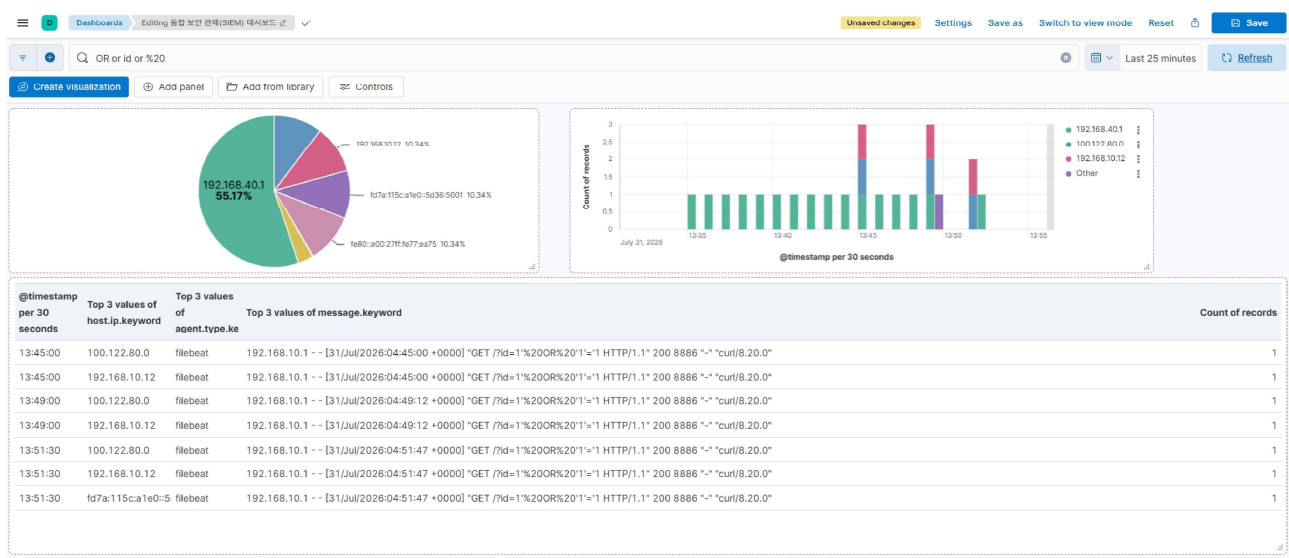
모의해킹 과정에서 발생한 공격 트래픽을 관제 대시보드에서 교차 검증한 결과, 정찰 단계의 포트 스캔부터 웹 애플리케이션 공격까지 다음과 같이 탐지됨을 확인하였습니다.

공격 유형	기법/도구	결과	탐지 근거
포트 스캔 (정찰)	Nmap 포트·스크립트 스캔 (http-enum)	탐지	게이트웨이 트래픽 급증(30초당 30건+ Spike) 시각화로 정찰 단계 식별
웹 취약점 스캔	Nikto	탐지	Access Log 급증 + User-Agent(자동화 도구) 기반 무차별 탐색 징후 식별
SQL Injection	GET 파라미터 주입	탐지	Query String 내 논리 연산자(OR)-SQL 특수문자 주입 패턴 KQL 필터링
XSS (스크립트 주입)	GET 파라미터 주입	탐지	URL 인코딩(%3Cscript%3E) 디코딩 후 script/alert 패턴 식별

증적 출처: SIEM 실시간 모니터링 검증 자료 (Nmap 15:08 / Nikto 13:06~13:16 / SQLi 13:45~13:51 / XSS 14:07 탐지 시각 기록)



[그림 4-4] 포트·서비스 스캔(Nmap http-enum) 시 게이트웨이 트래픽 급증(Spike, 30초당 약 4,600건) 탐지



[그림 4-5] SQL Injection 시도 시 L7 웹로그 기반 이상 징후 탐지

관제 검증 환경에서 실제 SIEM에 수집·탐지된 공격 로그를 요약하면 다음과 같습니다. 공격자 IP·타겟 IP와 함께 탐지된 원문 메시지가 로그 레벨에서 확보되어, 관제 체계가 각 공격을 실제로 식별하였음을 증명합니다.

다.

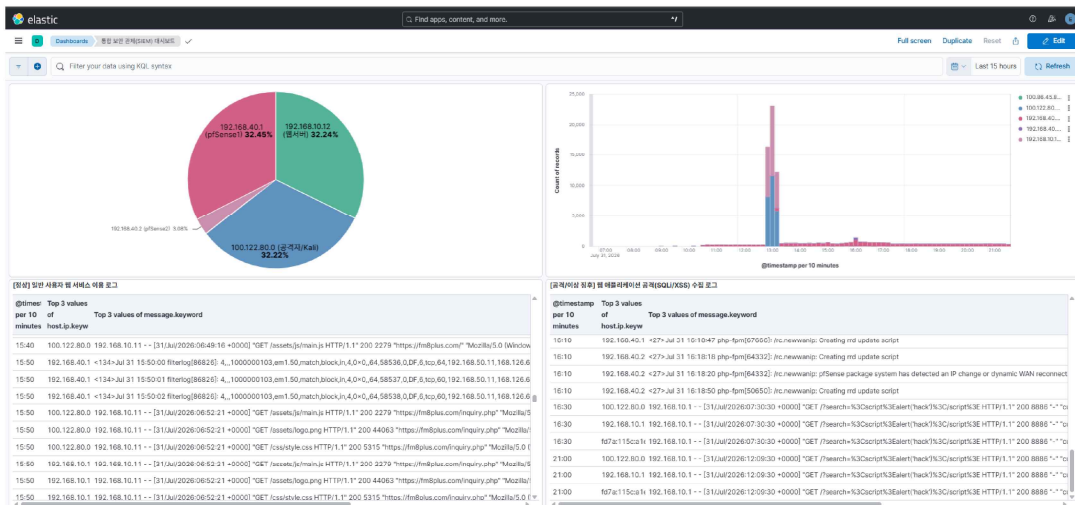
공격 유형	공격자 IP	타겟 IP	수집 소스	탐지된 주요 메시지 / 쿼리	비고
Port Scan	100.122.80.0	192.168.40.1	pfSense 방화벽 로그 (pre-NAT)	단시간 다수 포트 접속 → 트래픽 급증 (Spike)	미인가 포트 탐색
Nikto	100.122.80.0	192.168.10.12	Apache access log (post-NAT)	자동화 스캐너 반복 요청 (User-Agent: Nikto/2.1.6)	무차별 취약점 탐색
SQL Injection	100.122.80.0	192.168.10.12	Apache access log (post-NAT)	GET /?id=1'%20OR%20'1'='1 HTTP/1.1 200 "curl/8.20.0"	SQL 주입 특수 문자 탐색
XSS Attack	100.122.80.0	192.168.10.12	Apache access log (post-NAT)	GET /?search=%3Cscript%3Ealert('hack')%3C/script%3E "curl/8.20.0"	웹 자바스크립트 주입 시도

네트워크 구성(관제 검증 환경) — 공격자(Kali) 100.122.80.0 / pfSense WAN 192.168.40.1 · LAN 192.168.40.2 / 웹서버 192.168.10.12

4.5 정상 vs 악성 트래픽 식별 검증

동일 시간대 수집 로그에서 정상 이용자 트래픽과 악성 공격 트래픽이 명확히 분리·식별됨을 검증하였습니다. 정상 요청은 표준 경로와 브라우저 User-Agent를 갖는 반면, 공격 트래픽은 특수문자 페이로드와 자동화 도구 식별자, 단시간 트래픽 급증(Spike)으로 구분됩니다.

구분	정상 이용자 트래픽	악성 공격 트래픽
요청 경로	GET /index.php 등 표준 경로	/?id=1' OR '1'='1, /?search=<script>... 등
요청 파라미터	특수문자 없는 일반 텍스트	SQL 구문(OR, ')·스크립트 태그(<script>) 포함
User-Agent	Mozilla/5.0 (실제 브라우저)	curl/8.20.0, Nikto/2.1.6 (자동화 도구)
트래픽 패턴	사람의 간헐적 요청	단시간 수십~수천 건 급증(Spike)
식별 방식	기본 Access Log 통계 반영	KQL 필터링·시그니처 기반 이상 징후 탐지



[그림 4-6] 정상 트래픽 vs 악성 공격 트래픽 실시간 대조 관제 화면

4.6 관제 유효성 종합 평가

관제 체계를 침해 대응 관점의 4단계(가시성·탐지·경보·차단)로 나누어 평가하면, 앞의 두 단계는 검증되었으나 뒤의 두 단계는 미구축 상태로 확인됩니다.

관제 단계	검증 결과	세부 내용
가시성(Visibility)	확보	공격자 IP·타깃·페이로드를 단일 대시보드에서 실시간 조회 가능
탐지(Detection)	검증	스캔·SQLi·XSS 등 주요 공격 유형을 KQL·시그니처로 식별
경보(Alerting)	미구축	담당자 수동 KQL 검색에 의존, 실시간 자동 알림 체계 부재
차단·대응(Response)	부분 검증	커스텀 룰 13종의 인라인 drop 차단은 실증(4.3), 다만 탐지 결과 기반 공격자 IP 동적 차단(SOAR)은 미연동

정리하면, 현재 관제 체계는 ‘공격을 눈으로 볼 수 있고(가시성) 찾아낼 수 있으며(탐지), 사전에 정의한 공격은 막을 수 있는(정적 차단)’ 단계까지 유효하게 동작합니다. 그러나 ‘공격 발생을 담당자에게 즉시 알리고(경보), 미지의 변형 공격까지 동적으로 차단하는(적응형 대응)’ 단계는 확보되지 않아, 실제 침해 시 초동 인지 속도가 여전히 사람의 개입에 의존하는 한계가 있습니다.

5. 취약점-관제 상관 분석

본 장은 Red Team이 실증한 5개 취약점 각각에 대해, 그 공격이 Blue Team 관제 체계에서 실제로 탐지 가능한지를 매핑한 것으로, 본 점검의 핵심 종합 분석에 해당합니다. ‘공격이 성공했는가’와 ‘그 공격을 탐지할 수 있는가’는 별개의 문제이며, 이 둘을 함께 보아야 실질적인 방어 공백이 드러납니다.

5.1 탐지 커버리지 매트릭스

Red Team 취약점	공격 성공	관제 탐지	탐지 가능성 / 사각지대
SQL Injection	성공	탐지	L7 웹로그의 OR·특수문자 패턴으로 식별 — SID 1000001·1000008로 차단(drop)
Stored XSS	성공	탐지	L7 웹로그의 <script>·alert 패턴으로 식별 — SID 1000002로 차단(drop)
File Upload (RCE)	성공	부분 탐지	업로드는 SID 1000004, 실행 시도는 SID 1000010으로 차단하고, 확장자 위장은 WAF 룰 2000003의 파일 내용 검사로 보완
Session Fixation	성공	제한적	세션 재사용이 정상 트래픽과 형태가 유사 — 대응 룰 없음, 세션ID 미변경 이벤트 탐지 로직 필요
IDOR	성공	사각지대	SID 1000006으로 탐지되나 정상 요청과 동일하여 alert 전용, WAF에 서도 패턴 구분 불가 — 차단 불가

→ 실증된 5개 취약점 중 관제로 확실히 탐지되는 것은 2건(SQLi·XSS)이며, 부분/제한적 탐지 2건, 완전 사각지대 1건(IDOR)으로 나타납니다.

5.2 탐지 사각지대 분석

탐지가 어려운 취약점들은 공통적으로 '공격 요청이 정상 요청과 형태적으로 구분되지 않는다'는 특성을 가집니다. 이는 시그니처(특정 문자열 패턴) 기반 탐지의 근본적 한계이기도 합니다.

- **IDOR** — 파라미터(member_id) 값만 바꾼 정상 형식의 요청이고 서버도 200 정상 응답을 반환하므로, 페이로드에 악성 문자열이 없습니다. 따라서 단일 요청 로그만으로는 탐지가 불가능하며, '동일 세션이 짧은 시간에 여러 식별자를 연속 조회'하는 행위 기반(UEBA) 상관분석이 필요합니다.
- **Session Fixation** — 로그인 전후 세션 ID가 동일하다는 것은 정상적인 세션 유지와 겹보기에 같습니다. 응답 헤더의 Set-Cookie 미발급 여부를 로그에서 추적하는 별도 탐지 로직이 있어야 합니다.
- **File Upload** — 업로드 요청 자체는 정상 트래픽에도 존재하므로, '업로드된 파일에 대한 직접 접근(예: /uploads/shell.php?cmd=)' 시점의 시그니처를 함께 감시해야 완결적으로 탐지됩니다.

이 분석은 SQL Injection 대응과 IDOR 대응이 전혀 다른 계층의 문제인 것처럼, 탐지 역시 시그니처 기반만으로는 불충분하며 행위·상관분석 기반 탐지가 병행되어야 함을 시사합니다.

6. 개선 필요사항

개선 과제는 공격 표면을 줄이는 '애플리케이션 보안', 탐지·대응 역량을 높이는 '관제 체계', 그리고 재발을 막는 '프로세스·아키텍처' 세 층위로 구분하여 제시합니다.

6.1 애플리케이션 보안 개선

- 모든 DB 쿼리에 Prepared Statement(파라미터 바인딩) 적용 — SQL Injection 원천 차단
- 사용자 입력 출력 시 htmlspecialchars() 등 HTML 인코딩 필수 적용 및 CSP 헤더 설정 — XSS 차단
- 로그인 성공 시 session_regenerate_id(true) 호출, 세션 쿠키에 HttpOnly·Secure·SameSite 속성 적용 — Session Fixation·쿠키 탈취 차단
- 리소스 요청 시 소유자와 세션 user_id 일치 여부를 매 요청 서버측 검증 — IDOR 차단
- 업로드 파일 확장자·MIME·매직바이트 화이트리스트 이중 검증, 랜덤 파일명 저장, 업로드 디렉터리 스크립트 실행 권한 제거 — File Upload/RCE 차단
- 평문 비밀번호 컬럼(password_plain) 즉시 제거, 인증은 password_hash + password_verify()로만 수행

6.2 보안 관제·탐지 체계 개선

- 자동 경보(Alert) 체계 구축 — 현재 수동 KQL 검색 의존. ElastAlert/Kibana Alerting 으로 임계치 초과 시 담당자 자동 통보(초동 대응 시간 단축).
- 정규식/Sigma 룰 기반 탐지 룰 등록 — 단순 키워드(script, OR) 매칭은 URL 인코딩 변형·WAF 우회예 취약. 정규표현식 기반 Elasticsearch Detection Rule 로 고도화.
- 행위·상관분석 기반 탐지 추가 — IDOR·Session Fixation 등 시그니처 사각지대를 '동일 세션의 연속 파라미터 변경' 같은 이상 행위 패턴으로 탐지.
- 오탐(False Positive) 정제 — 정상 사용자의 검색어에 script·OR 가 포함된 경우를 공격으로 오탐하지 않도록 필터링 예외 조건 설계.
- 탐지→차단 자동화(SOAR) 연동 및 룰셋 우회 대응 — 현재 Suricata 인라인 차단은 고정 시그니처 기반이므로 인코딩 변형·명령어 치환에 우회 가능. content 매칭을 PCRE 정규식·URI 정규화로 고도화하고, SIEM 탐지 시 공격자 IP 를 방화벽 정책에 자동 등록하는 Playbook 을 병행.
- MITRE ATT&CK 매핑 — 수집 로그·탐지 룰을 ATT&CK Matrix 에 매핑하여 방어 커버리지 공백을 체계적으로 관리.

6.3 프로세스·아키텍처 개선

- 개발 단계 시큐어 코딩 가이드라인 수립 — 다수 취약점이 '입력값 검증 부재'라는 공통 원인을 공유하므로, 개별 패치가 아닌 구조적 예방이 필요.
- WAF/IDS 룰셋 적용 전·후 동일 payload 재테스트로 방어 효과를 정량 검증하는 절차 정착.
- DB 계정 최소 권한 원칙 적용 — 웹 애플리케이션 계정에 DROP·전체 테이블 접근 권한 제한으로 SQLi 성공 시 피해 최소화.

7. 종합 결론 및 대응 우선순위

7.1 종합 보안 성숙도 평가

FM 8+ 인프라는 '공격이 성공하는가'와 '그 공격을 볼 수 있는가'라는 두 축에서 상반된 결과를 보였습니다. 애플리케이션 계층은 진단 대상 전 항목이 익스플로잇 가능한 취약한 상태였던 반면, 관제 계층은 커스텀 룰 18종(IPS 15 · WAF 3)으로 주요 공격을 실시간 탐지·차단하고 시각화하는 데 성공하였습니다. 즉 '방어(예방)' 성숙도는 낮으나 '탐지(가시성)' 성숙도는 확보된, 전형적인 탐지 우선형 구성입니다.

다만 차단이 사전에 정의된 시그니처 범위 안에서만 성립하고 자동 경보로 이어지지 못하며, 정상 요청과 유사한 공격(IDOR)에 대한 탐지 공백이 존재하므로, 실제 침해사고 대응 관점에서는 '아는 공격은 막지만 모르는 공격은 늦게 아는' 단계에 위치합니다. 애플리케이션 시큐어 코딩으로 공격 표면을 줄이고, 관제 자동화·행위분석으로 탐지 공백과 대응 지연을 보완하는 것이 다음 성숙 단계로의 핵심 과제입니다.

7.2 대응 우선순위 로드맵

우선순위	대상 영역	핵심 조치	기대 효과
1순위	File Upload / SQL Injection	입력 검증 · Prepared Statement 적용	RCE 및 DB 전체 탈취 경로 원천 차단
2순위	XSS / Session Fixation	출력 인코딩 · HttpOnly · 세션 재발급	세션 하이재킹 공격 체인 차단
3순위	관제 자동화	자동 경보(Alert) · Sigma 룰 · 상관 분석 도입	탐지 공백 해소 및 초동 대응 시간 단축
4순위	IDOR / 공통	인가 로직 · 평문 비번 제거 · WAF/IDS 룰셋	개인정보 유출 방지 및 2차 피해 최소화